



DOCUMENTACIÓN TÉCNICA Y OPERATIVA

Proyecto Haro Seminuevos

Guía general del sitio público, panel administrativo, datos, configuración y mantenimiento.

ALCANCE	Raíz pública del proyecto y carpeta admin/
COMPATIBILIDAD	PHP 8.3 o superior y MariaDB/MySQL mediante mysqli
VERSIÓN	1.0 - 2 de septiembre de 2026
CARÁCTER	Documento de arquitectura, instalación, operación y evolución

Nota de seguridad

La documentación enumera nombres de variables de entorno, pero omite deliberadamente usuarios, contraseñas, tokens y valores operativos.

01 Resumen ejecutivo

Qué es el sistema, qué cubre este documento y cuál es su estado técnico.

Haro Seminuevos es una aplicación web PHP para publicar inventario automotriz y administrar su ciclo comercial. La raíz del proyecto concentra la experiencia pública; **admin/** reúne autenticación, catálogos, inventario, clientes, publicaciones, estadísticas y un submódulo de banca para ventas, pagos y almacenes.

Alcance documentado

- Páginas PHP ubicadas directamente en la raíz y sus recursos públicos.
- Todo el árbol **admin/**, incluidas sus APIs, plantillas, tareas y módulo **admin/banca/**.
- Conectividad a base de datos, variables de entorno, modelo de datos conceptual y consultas críticas.
- Procedimientos de instalación, validación, operación, seguridad y mantenimiento.

Fuera de alcance

Las demás carpetas de la raíz se consideran fuera del encargo, salvo recursos estáticos que son consumidos directamente por las páginas públicas o administrativas.

Estado observado

Área	Resultado
Compatibilidad	572 archivos PHP del alcance pasan validación sintáctica sin fallas.
Configuración	Los conectores de datos y el publicador de Facebook leen parámetros desde .env .
Datos	Conexiones verificadas con utf8mb4 y reutilización perezosa de mysql.
Rendimiento	Se redujeron patrones N+1, se agruparon estadísticas y se aplicaron 17 índices.
Pruebas web	Rutas públicas y administrativas críticas responden con estados HTTP esperados.

Lectura recomendada	Desarrollo: secciones 03, 06, 07 y 09. Operación: 08, 11 y 12. Seguridad y evolución: 10 y 13.
----------------------------	--

02 Arquitectura de la solución

Vista lógica de capas, ejecución y dependencias principales.

NAVEGADOR	Sitio público y panel administrativo
PRESENTACIÓN	PHP + HTML, Bootstrap 4, jQuery y complementos de interfaz
APLICACIÓN	Páginas PHP, controladores por acción y administradores de dominio
DOMINIO	Autos, catálogos, clientes, ventas, pagos, almacenes, usuarios y estadísticas
DATOS	Conectores mysqli compartidos, variables de .env y MariaDB
INTEGRACIONES	Correo SMTP, Meta/Facebook, Mercado Libre y tareas programadas

Flujo de una petición

Paso	Descripción
1	El navegador solicita una página pública o una pantalla protegida de admin/ .
2	La página incluye plantillas, valida sesión cuando aplica y obtiene parámetros de entrada.
3	Un administrador de dominio coordina entidades y consultas, o una API despacha por el parámetro POST accion .
4	El conector crea o reutiliza mysqli con los valores cargados por env.php .
5	La respuesta se presenta como HTML o como JSON/texto para llamadas asíncronas.

Componentes transversales

Componente	Responsabilidad
env.php	Carga el archivo raíz .env sin depender de Composer y expone lectura tipada por nombre.
conectorBD.php	Abre mysqli bajo demanda, configura utf8mb4 , reutiliza la conexión y encapsula errores.
templates/	Cabeceras, menús, pie, control de sesión y recursos compartidos.
administradores	Agrupar reglas y operaciones para autos, usuarios, clientes, pagos, ventas y otras entidades.
api*.php	Puntos de entrada para operaciones AJAX y acciones administrativas.

03 Estructura del proyecto

Mapa práctico de directorios y archivos canónicos.

```
C:\laragon\www\haro_project\
|- .env / .env.example / .htaccess / .gitignore
|- env.php
|- index.php
|- inventory-list.php
|- vehicle-details.php
|- contacts.php / car-hunter.php / suscripciones.php / cotizador.php
|- assets/ recursos usados por la interfaz
`- admin/
  |- index.php / login.php
  |- autos*.php / galeria.php / catalogos*.php / users.php
  |- api/ dominio, conectores y endpoints
  |- templates/ navegación y control de sesión
  |- sql/optimizacion_indices.sql
  `- banca/
    |- pantallas de ventas, pagos, clientes, inventario y almacenes
    |- api/ dominio y endpoints de banca
    `- templates/ navegación y sesión de banca
```

Convención de archivos

Patrón	Interpretación
index.php	Página de abordaje pública y punto principal del sitio.
apiNombre.php	Despachador de acciones de un dominio administrativo.
Administrador*.php	Servicio de acceso y coordinación de datos.
Nombre.php	Entidad o modelo del dominio.
*_o.php, *_dev.php, sufijos 2 o _pre	Variantes históricas o de prueba. No deben considerarse canónicas sin una verificación funcional.

Deuda estructural

Existen varias versiones alternativas de páginas y endpoints. Antes de retirarlas, identificar llamadas reales, cubrirlas con pruebas y conservar una sola implementación canónica.

04 Sitio público

Responsabilidades de las rutas principales de la raíz.

Archivo	Función principal	Datos destacados
index.php	Página de abordaje, inventario destacado, marcas y filtros.	Autos activos, banners, contadores y rangos de precio.
inventory-list.php	Listado navegable con búsqueda, filtros y paginación.	Marca, modelo, año, precio y atributos del vehículo.
vehicle-details.php	Ficha individual de un vehículo.	Datos técnicos, precio, imágenes y estado.
car-hunter.php	Captura la solicitud de búsqueda asistida.	Preferencias, presupuesto y contacto.
contacts.php	Formulario general de contacto.	Datos del prospecto y mensaje.
suscripciones.php	Alta de suscriptores.	Correo y registro de interés.
cotizador.php	Interfaz de cotización.	Vehículo y parámetros comerciales.
dealers.php / dealers-info.php	Presentación de información para distribuidores.	Contenido editorial y llamadas a la acción.
blog-main.php / blog-post.php	Vistas editoriales del blog.	Listado y detalle de contenido.

Comportamiento esperado

- Los identificadores numéricos deben validarse antes de consultar. La ficha devuelve 400 para un identificador inválido y 404 si el auto no existe.
- Los filtros se resuelven en SQL para evitar cargar y descartar registros en PHP.
- Las imágenes y catálogos se cargan por lote o con caché para impedir consultas repetitivas por cada auto.
- La codificación de salida y de conexión debe permanecer en UTF-8/utf8mb4.

Capa visual actual

La interfaz utiliza Bootstrap 4.1.3, jQuery 3.3.1 con Migrate, Font Awesome 6.5, bootstrap-select, Magnific Popup, Easy Pie Chart, Slider Pro y Slick. Cualquier actualización debe hacerse por etapas y con revisión visual, porque la estructura y los complementos comparten estilos y eventos.

05 Panel administrativo y banca

Módulos funcionales protegidos por sesión y permisos.

Módulo	Pantallas o clases	Responsabilidad
Acceso	login.php, templates	Inicio de sesión y validación de sesionUsuario , permisos generales y permiso de banca.
Autos	autos.php, autos-nuevo.php, autos_mod.php	Alta, edición, consulta y publicación de vehículos.
Ciclo de inventario	autos-consig.php, autos-inactivo.php, autos-ventas.php	Consignación, pausados/inactivos e históricos de venta.
Galería	galeria.php, Imagen	Carga, orden y asociación de fotografías.
Catálogos	marca, modelo, interiores, transmisiones	Datos normalizados usados en altas y filtros.
Usuarios	users.php, Usuario, administradorUsuarios	Cuentas, permisos y recuperación de acceso.
Prospectos	Contacto, CarHunter, notificaciones	Seguimiento de contactos y búsquedas solicitadas.
Estadísticas	Visita, Mes, VisitasAuto	Métricas mensuales y actividad por vehículo.
Banca	Venta, Pago, PagoEvento, ClienteBanca, Almacen	Ventas, saldos, pagos, clientes, almacenes e inventario financiero.

Sesión y autorización

La sesión administrativa se concentra en **\$_SESSION['sesionUsuario']** y conserva identificador, permisos, permiso de banca e imagen. Las plantillas bloquean pantallas protegidas y **admin/index.php** redirige al área de banca. Los endpoints deben repetir la autorización en servidor; ocultar un botón no sustituye el control de permisos.

Tareas operativas

Archivo	Propósito
borrarPausadosYEliminadosSoloAutos.php	Limpieza controlada de autos pausados o eliminados.
jobAsignarPortada.php	Asignación de portada para vehículos.
notificadorAutos.php / notificadorAutosBet.php	Notificaciones relacionadas con el estado del inventario.
recividorEmail.php / dev-recividorEmail.php	Recepción o procesamiento de correo.
posteadorFacebook.php	Publicación en Facebook con token leído desde el entorno.

06 APIs y servicios de dominio

Mapa de endpoints y patrón de interacción administrativa.

Grupo	Endpoints representativos	Operaciones
Autos	apiAuto.php, apiAutoPmail.php, apiAutoPrueba.php	CRUD, imágenes, portada, pausa, banner, publicación, historial y validación de almacén.
Catálogos	apiEditor.php	Marcas, modelos, interiores y transmisiones.
Personas	apiCliente.php, apiClientes.php, apiUsuarios.php	Clientes, usuarios, sesión, permisos, token y recuperación.
Relación comercial	apiContactos.php, apiCarHunter.php	Contactos, solicitudes y notificaciones.
Contenido e integración	apiPublicaciones.php, apiMercadolibre.php	Publicaciones y comunicación con canales externos.
Sistema	apiConfiguraciones.php, apiEstadisticas.php	Parámetros y agregación de métricas.
Banca	apiAlmacen.php, apiClientes.php, apiPagos.php, apiVentas.php	Almacenes, clientes, abonos, eventos y ventas.

Patrón de llamada

Etapas	Comportamiento
Entrada	Solicitud HTTP, normalmente POST, con accion y los campos de la operación.
Despacho	El endpoint identifica la acción, valida datos y llama al administrador de dominio.
Persistencia	El administrador ejecuta consultas por medio del conector mysqli compartido.
Salida	Respuesta JSON o texto consumido por JavaScript; los errores de conexión se registran sin revelar secretos.

Contrato recomendado para nuevas acciones

- Aceptar solamente el método HTTP esperado y devolver 405 para otros métodos.
- Validar tipos, longitudes, listas permitidas e identificadores antes de llegar a SQL.
- Aplicar autorización por acción en el servidor y protección CSRF en cambios de estado.
- Usar sentencias preparadas y respuestas JSON consistentes: éxito, datos, mensaje y código.
- Registrar contexto técnico suficiente sin incluir contraseñas, tokens ni datos personales sensibles.

07 Modelo de datos conceptual

Entidades centrales y relaciones funcionales observadas.

Área	Tablas principales	Relaciones conceptuales
Inventario	auto, autohistorico, autoventas, imagen	Un auto tiene imágenes; el histórico y la venta conservan id_previo .
Catálogos	marca, modelo, interiores, transmision	Marca agrupa modelos; auto referencia los catálogos.
Personas	cliente, clientes_banca, usuario, contactos, suscriptor	Propietarios, compradores, operadores y prospectos.
Comercial	venta, pago, pago_evento	Una venta pertenece a un cliente y admite pagos y eventos.
Operación	almacenes, inventario_dia, ventas_dia	Ubicación, verificaciones y cortes operativos.
Seguimiento	log_cambio_auto, log_envio_correo, visitasauto	Trazabilidad de cambios, envíos y visitas.
Marketing	car_hunter, publicaciones, notficaiones_s	Preferencias de búsqueda, canales y avisos.
Sistema	configuraciones	Parámetros internos de comportamiento.

Relaciones críticas

Origen	Cardinalidad	Destino
marca	1 a N	modelo
auto	N a 1	marca, modelo, transmision, interiores, cliente y almacen
auto	1 a N	imagen, visitas y registros de cambio
venta	N a 1	clientes_banca y auto histórico
venta	1 a N	pago y pago_evento

Compatibilidad de esquema

La tabla **notficaiones_s** conserva una grafía histórica. No debe renombrarse directamente en producción: se requiere migración, compatibilidad temporal y verificación de todas las referencias.

Integridad recomendada

Mantener claves primarias e índices de consulta; documentar claves foráneas existentes o lógicas; ejecutar cambios dentro de transacciones cuando involucren venta, saldo o inventario; y conservar copias verificadas antes de toda migración.

08 Instalación y configuración

Procedimiento reproducible para un entorno local o servidor equivalente.

Requisito	Referencia
PHP	8.3 o superior, extensión mysqli habilitada.
Base de datos	MariaDB/MySQL compatible; conexión con juego de caracteres utf8mb4.
Servidor web	Apache/Laragon en el entorno observado; document root apuntando al proyecto.
Permisos	Lectura del código y escritura solamente en directorios que reciban archivos o registros.
Integraciones	Credenciales válidas de correo y redes sociales solo cuando se habiliten esas funciones.

Secuencia de puesta en marcha

1. Copiar el proyecto en el document root y conservar la estructura de rutas.
2. Crear **.env** en la raíz tomando **.env.example** como plantilla. No copiar valores desde otro entorno sin autorización.
3. Crear o restaurar la base de datos correspondiente y asignar un usuario con privilegios mínimos necesarios.
4. Completar las variables de base de datos y, si se usará el publicador, **FACEBOOK_ACCESS_TOKEN**.
5. Ejecutar **admin/sql/optimizacion_indices.sql** sobre la base objetivo. El script usa índices repetibles cuando el motor lo permite.
6. Confirmar que el servidor bloquea el acceso HTTP a **.env** y archivos de respaldo.
7. Abrir la portada, el inventario, una ficha válida y el acceso administrativo; después revisar el registro de PHP y del servidor web.

Comandos de comprobación

```
php -v
php -l index.php
php -l admin/api/conectorBD.php
php -l admin/banca/api/conectorBD.php
```

09 Variables de entorno y conectividad

Contrato de configuración sin incluir valores secretos.

Variable	Uso	Observación
DB_HOST	Servidor de base de datos.	Nombre o IP accesible desde PHP.
DB_PORT	Puerto TCP.	Normalmente 3306; usar el asignado al entorno.
DB_DATABASE	Esquema de la aplicación.	Debe existir antes de iniciar.
DB_USERNAME	Usuario de aplicación.	Aplicar mínimo privilegio.
DB_PASSWORD	Contraseña del usuario.	Nunca registrar ni versionar.
DB_CHARSET	Codificación de la conexión.	Mantener utf8mb4 .
FACEBOOK_ACCESS_TOKEN	Token del publicador de Facebook.	Rotar al vencer o ante exposición.

Carga de configuración

Los conectores de **admin/api/conectorBD.php** y **admin/banca/api/conectorBD.php** cargan **env.php** con rutas basadas en **__DIR__**. La conexión se crea al primer uso, se reutiliza dentro de la petición y configura utf8mb4. El publicador de Facebook solicita su token con **haroEnv('FACEBOOK_ACCESS_TOKEN')**.

Protección obligatoria

- Mantener **.env** fuera del control de versiones; **.env.example** solo contiene nombres y valores de muestra.
- La regla actual de **.htaccess** bloquea archivos **.env*** en Apache/Laragon. En Nginx o IIS se debe crear una regla equivalente.
- No exponer errores mysqli al navegador. Registrar el detalle técnico en un destino no público.
- Separar credenciales por ambiente y rotarlas ante cualquier sospecha de filtración.

Acción crítica pendiente

Se detectaron credenciales SMTP incrustadas en varios flujos de correo. Deben trasladarse a variables de entorno y rotarse, sin copiar sus valores a documentación ni registros.

10 Optimización de consultas

Cambios aplicados para conservar resultados con menos viajes y trabajo de base de datos.

Problema	Solución aplicada	Impacto
Consultas N+1 al listar autos	Carga adaptable por lote y caché de catálogos, propietarios e imágenes.	Menos conexiones lógicas y latencia estable al crecer el inventario.
Pagos consultados por cada venta	SalDOS y totales agregados en la consulta principal; eventos recuperados por lote.	La vista de ventas evita repetición por fila.
Estadísticas por mes	Los 12 meses se agrupan en una sola consulta.	De 12 consultas equivalentes a 1.
Autos sin publicación	Uso de NOT EXISTS para excluir coincidencias.	Plan de ejecución más directo y semántica clara.
Filtros en memoria	Predicados trasladados a SQL.	Se transfieren y procesan solo filas útiles.
Recuperación del último ID	Uso de insert_id en lugar de MAX(id) .	Evita carreras entre inserciones concurrentes.
Búsquedas y uniones	17 índices incorporados mediante el script de optimización.	Menor costo en filtros, relaciones y ordenamientos frecuentes.

Resultados de referencia

Caso	Antes	Después observado
Listado de 128 autos	Aproximadamente 0.095 s	0.027 a 0.050 s
Consulta de 66 ventas	Aproximadamente 0.037 s	0.002 a 0.009 s

Criterios de conservación

Las optimizaciones se aceptaron solo después de comparar resultados funcionales. Se verificaron los mismos identificadores y orden de autos activos, además de los saldos de todas las ventas. Las cifras son referencias del entorno local, no un SLA de producción.

Regla para cambios futuros

Medir primero, revisar el plan de ejecución, reducir filas y viajes, agregar índices selectivos y volver a comparar el conjunto completo de resultados. Evitar índices redundantes: cada índice acelera lecturas, pero añade costo a inserciones y actualizaciones.

11 Validación y pruebas

Evidencia disponible y conjunto mínimo de regresión.

Prueba	Cobertura	Resultado observado
Lint PHP	Archivos PHP directos de raíz y todo admin/ .	572 archivos, 0 fallas.
Nivel de errores	Ejecución bajo PHP 8.5 con E_ALL como verificación adelantada.	Sin errores sintácticos del alcance.
Conectores	Conector general y conector de banca.	Conexión correcta y charset utf8mb4.
Portada e inventario	index.php e inventory-list.php.	HTTP 200.
Detalle válido	vehicle-details.php con auto existente.	HTTP 200.
Detalle inválido	Identificador con formato incorrecto.	HTTP 400.
Administración	login.php y admin/index.php.	Login 200; índice redirige con 302 a banca.
Salida web	Cuerpos de respuestas críticas.	Sin warning, fatal error ni deprecated visible.

Pruebas mínimas antes de publicar

- Crear, editar, pausar, reactivar y consultar un auto con varias imágenes.
- Probar filtros combinados, paginación, detalle inexistente y caracteres acentuados.
- Iniciar y cerrar sesión; comprobar un usuario sin permiso y otro con permiso de banca.
- Registrar cliente, venta, pago y evento; verificar saldo y trazabilidad.
- Ejecutar formularios de contacto y Car Hunter en un ambiente de correo controlado.
- Confirmar que **/.env**, respaldos y registros no son descargables por HTTP.
- Revisar registros de PHP, servidor web y base de datos inmediatamente después de la prueba.

12 Operación y mantenimiento

Rutinas para sostener disponibilidad, rendimiento y trazabilidad.

Frecuencia	Actividad	Evidencia
Diaria	Revisar errores PHP/HTTP, tareas fallidas, espacio disponible y operaciones comerciales incompletas.	Registro revisado y anomalías asignadas.
Semanal	Verificar respaldos restaurables, colas de notificación, publicaciones e inventario no verificado.	Prueba de restauración o muestra validada.
Mensual	Analizar consultas lentas, crecimiento de tablas e índices; revisar usuarios y permisos.	Reporte de tendencias y cambios aprobados.
Por versión	Ejecutar lint, pruebas HTTP, flujo administrativo, respaldo y plan de reversión.	Lista de verificación firmada.
Por incidente	Preservar registros, limitar impacto, rotar secretos afectados y documentar causa raíz.	Cronología, acciones y prevención.

Respaldo y restauración

- Respaldar base de datos y archivos cargados con la misma marca temporal.
- Cifrar respaldos, limitar acceso y definir una retención acorde con datos personales y obligaciones del negocio.
- Probar restauraciones en un entorno aislado. Un respaldo no verificado no debe considerarse recuperable.
- Antes de migraciones, conservar un punto de retorno y documentar exactamente la versión de esquema y código.

Monitoreo recomendado

Registrar tiempos de respuesta p50/p95, tasa de errores 4xx/5xx, conexiones y consultas lentas, tamaño de tablas, fallas de correo/publicación y resultados de tareas programadas. Establecer alertas a partir de una línea base real, no de umbrales arbitrarios.

Despliegue seguro

Separar ambientes; cargar secretos en el servidor; ejecutar migraciones e índices de forma controlada; validar rutas críticas; y habilitar la versión solo después del humo funcional. La reversión debe restaurar código y esquema compatibles.

13 Seguridad y hoja de ruta

Riesgos prioritarios y evolución recomendada.

Prioridad	Hallazgo	Acción recomendada
P0	Credenciales SMTP incrustadas en código.	Mover a <code>.env</code> o gestor de secretos, rotar credenciales y verificar historial/versiones desplegadas.
P0	Token de Facebook previamente incrustado.	Ya se externalizó; completar la rotación del token en Meta y revocar el anterior.
P1	Consultas SQL construidas por interpolación en varias rutas.	Migrar gradualmente a sentencias preparadas, empezando por autenticación y escrituras.
P1	Contraseñas tratadas con SHA-1 en código heredado.	Adoptar <code>password_hash/password_verify</code> con actualización transparente al iniciar sesión.
P1	Autorización y CSRF no uniformes entre endpoints.	Centralizar guardas de sesión, permisos, método HTTP y tokens CSRF.
P2	Versiones antiguas de Bootstrap/jQuery y complementos.	Actualizar en una rama de compatibilidad con pruebas visuales y funcionales.
P2	Graph API fijada a una versión antigua en el publicador.	Planificar actualización, revisar permisos y probar en una aplicación de desarrollo.
P2	Archivos duplicados o históricos activos en el árbol.	Medir uso, elegir canónicos, archivar y retirar después de cubrir dependencias.
P3	Respuestas de API no totalmente uniformes.	Definir contrato JSON, códigos HTTP, validación y manejo de errores común.

Orden sugerido

Primero rotar y externalizar secretos restantes. Después asegurar autenticación, escrituras y permisos. A continuación normalizar APIs y retirar duplicados. Finalmente abordar la actualización visual y de integraciones externas. Cada fase debe incluir métricas, pruebas y reversión.

Principio rector

Una mejora no está completa si cambia los resultados esperados, oculta un error o depende de un secreto dentro del repositorio.

14 Apéndice de referencia

Archivos esenciales y lista de entrega para futuras versiones.

Archivo	Uso
/.env.example	Contrato de variables sin secretos.
/env.php	Carga central de configuración.
/.htaccess	Protección Apache de archivos de entorno.
/index.php	Entrada pública principal.
/inventory-list.php	Inventario filtrable y paginado.
/vehicle-details.php	Ficha individual y respuestas 400/404.
/admin/api/conectorBD.php	Conexión de datos administrativa.
/admin/banca/api/conectorBD.php	Conexión de datos del módulo banca.
/admin/sql/optimizacion_indices.sql	Índices de rendimiento aplicados.
/admin/posteadorFacebook.php	Publicador que consume FACEBOOK_ACCESS_TOKEN.

Lista de entrega

- Código PHP validado con la versión objetivo.
- Variables del ambiente completas y secretos fuera del código.
- Migraciones e índices ejecutados y registrados.
- Pruebas públicas, administrativas y de banca aprobadas.
- Registros sin errores nuevos y métricas comparadas contra la línea base.
- Respaldo restaurable y plan de reversión disponible.
- Cambios, riesgos conocidos y responsable de operación documentados.

Glosario mínimo

Término	Definición
Auto activo	Vehículo disponible para los flujos públicos según sus banderas de estado.
Consignación	Vehículo administrado para venta con propietario asociado.
Banca	Submódulo administrativo para ventas, pagos, saldos, clientes y almacenes.
Car Hunter	Solicitud de búsqueda de un vehículo de acuerdo con preferencias del prospecto.
N+1	Patrón en el que una consulta inicial provoca otra consulta por cada fila obtenida.
Smoke test	Comprobación breve de que las rutas y operaciones críticas funcionan después de un cambio.

Fin del documento